MULUNGUSHI UNIVERSITY

School of Engineering and Technology

Advanced Cybersecurity and Ethical Hacking

Unit 3: Reconnaissance and OSINT

ICS 441 • Lecture 2 Lecturer: Mr. M Bwalya



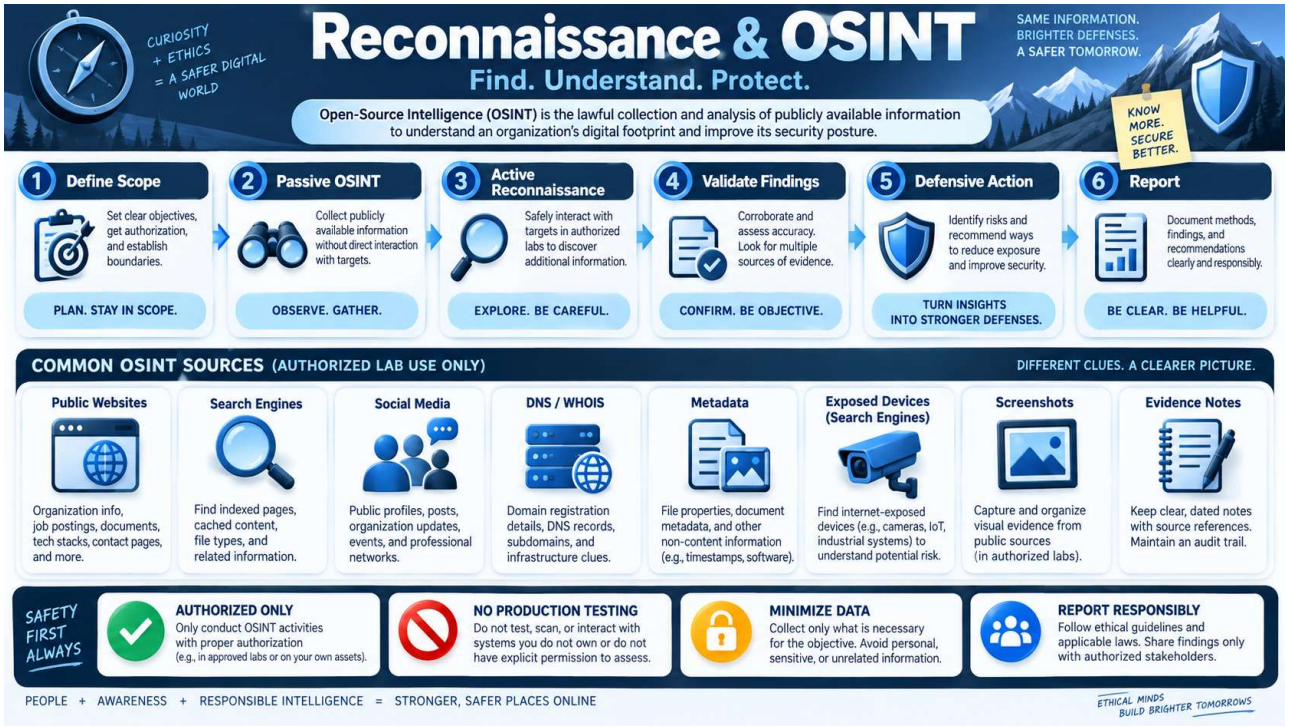
Learning outcomes for Unit 3

By the end of this unit, students should be able to:

- Explain reconnaissance and OSINT in ethical hacking.
- Differentiate passive and active reconnaissance using safe examples.
- Identify authorised OSINT sources and the risks they reveal.
- Use reconnaissance findings to map attack surface and improve defence.
- Document findings using clear bullets, evidence and responsible language.

Reconnaissance is useful only when it is legal, scoped and defensive.

Big picture: Reconnaissance and OSINT



Generated teaching visual: OSINT should find, understand and protect — not harm.

What is reconnaissance?

Clear definition

- Reconnaissance is the first stage of an ethical hacking or penetration test.
- It focuses on gathering information about a target before deeper testing.
- It helps testers understand assets, technologies, people, services and exposures.
- It must be performed only within authorised scope and approved rules of engagement.
- Good reconnaissance reduces guesswork and makes testing more focused.

First understand the target; then test safely.

What is OSINT?



• Class discussion: what public information about an institution can attackers and defenders both see?

Passive vs active reconnaissance

Area	Passive reconnaissance	Active reconnaissance	Teaching point
Interaction	No direct contact with target systems	Direct engagement with target systems	Passive is usually lower risk
Examples	Websites, search engines, job posts, social media	Ping, banner checks, approved scanning	Active actions require explicit authorization
Detection risk	Low visibility to the target	May appear in logs and alerts	Plan timing and rate limits
Use in labs	Public and safe learning tasks	Isolated lab or approved target only	Never test production without written consent
Main value	Build context and public footprint	Validate live services and exposures	Use both responsibly

Students must explain the legal boundary, not just define the terms.

Passive reconnaissance

- No direct interaction with the target; it leaves no footprint on target systems.
- Sources include public websites, social media, job postings and search engines.
- Tools may include Google search operators, Shodan, public repositories and link analysis tools.
- Goal: identify infrastructure, technologies and possible exposures without alerting the target.
- Use only public data and document sources carefully.

Passive does not mean careless; privacy still matters.

Active reconnaissance

- Active reconnaissance involves direct engagement with the target network or system.
- Examples include network discovery, banner grabbing and approved service checks.
- It has higher risk of detection because systems may log the activity.
- It must be approved in the ROE before it is attempted.
- Use rate limits, lab targets and monitoring to avoid disruption.

Active testing without approval is not ethical hacking.

Why reconnaissance matters

For ethical hacking

- It is the foundation for later testing.
- It reveals technologies, entry points and exposed assets.
- It helps testers focus on high-value systems.
- It reduces blind scanning and wasted effort.

For defence

- It shows what attackers can learn before attacking.
- It helps security teams reduce public exposure.
- It supports early threat detection and monitoring.
- It strengthens incident response preparation.

Reconnaissance, risk and compliance

Risk assessment value

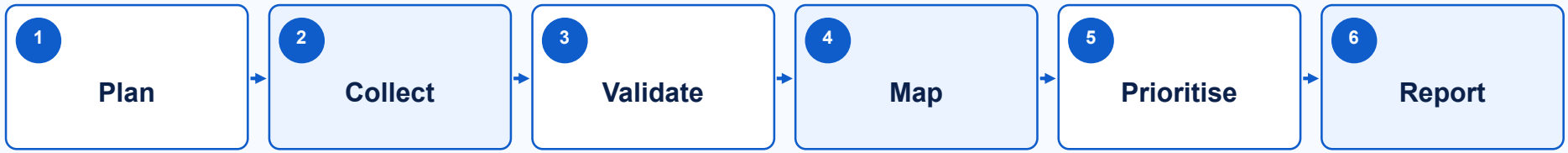
- Exposed systems can be prioritised by likelihood and impact.
- Findings guide patching, hardening and access review.
- High-risk assets should be escalated early.
- The output becomes evidence for a risk register.

Compliance and reporting value

- Many security standards expect structured assessment evidence.
- A clear recon report shows due care and due diligence.
- Repeatable methods support auditability.
- Findings should be factual, dated and traceable.

Reconnaissance workflow

A safe, repeatable learning process



Plan	Collect	Validate	Map	Prioritise	Report
Define scope and objectives.	Gather public information.	Confirm with multiple sources.	Group assets and exposures.	Link findings to risk.	Recommend defensive action.

Safety principle: collect only what is authorised, public, necessary and useful for defence.

Traditional OSINT methods



- Ask students: Which of these sources would help map a university public footprint?

Modern OSINT resources



• Use only legal, public and approved sources; avoid restricted or unauthorised environments.

Common OSINT source categories

Public web sources

- Institutional websites and subpages.
- News articles and public notices.
- Blogs, reports and public documents.
- Search engine cached pages.

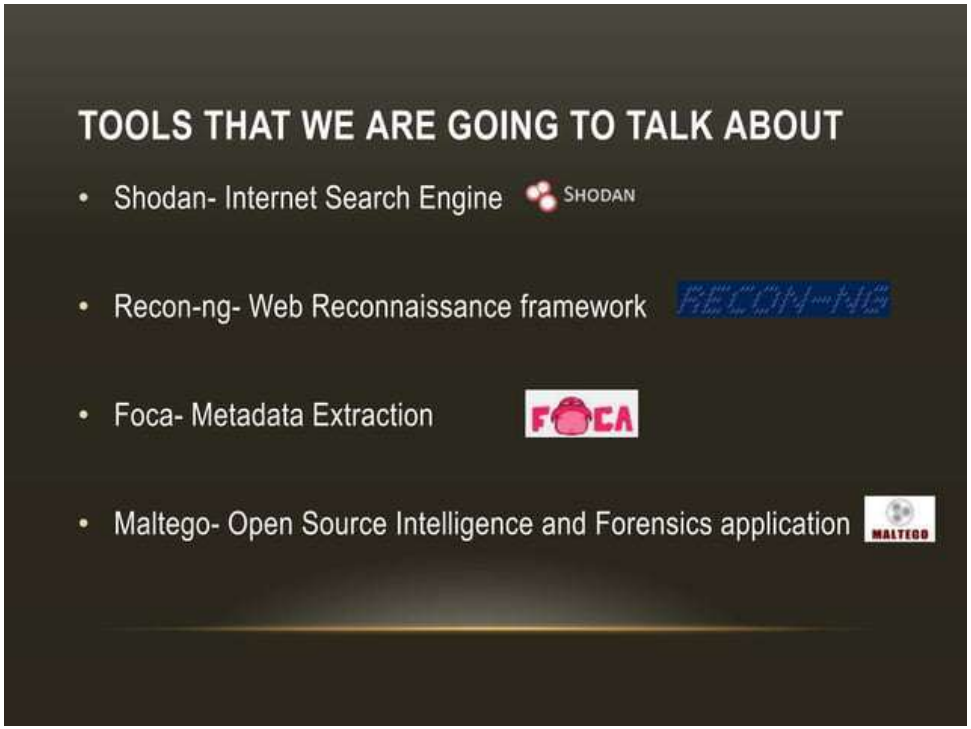
People and organisation sources

- Social media posts and profiles.
- Staff directories and job adverts.
- Conference pages and project sites.
- Public professional profiles.

Technical sources

- DNS and WHOIS records.
- Certificate transparency records.
- Public repositories and leaks.
- Exposed service intelligence.

Tools introduced



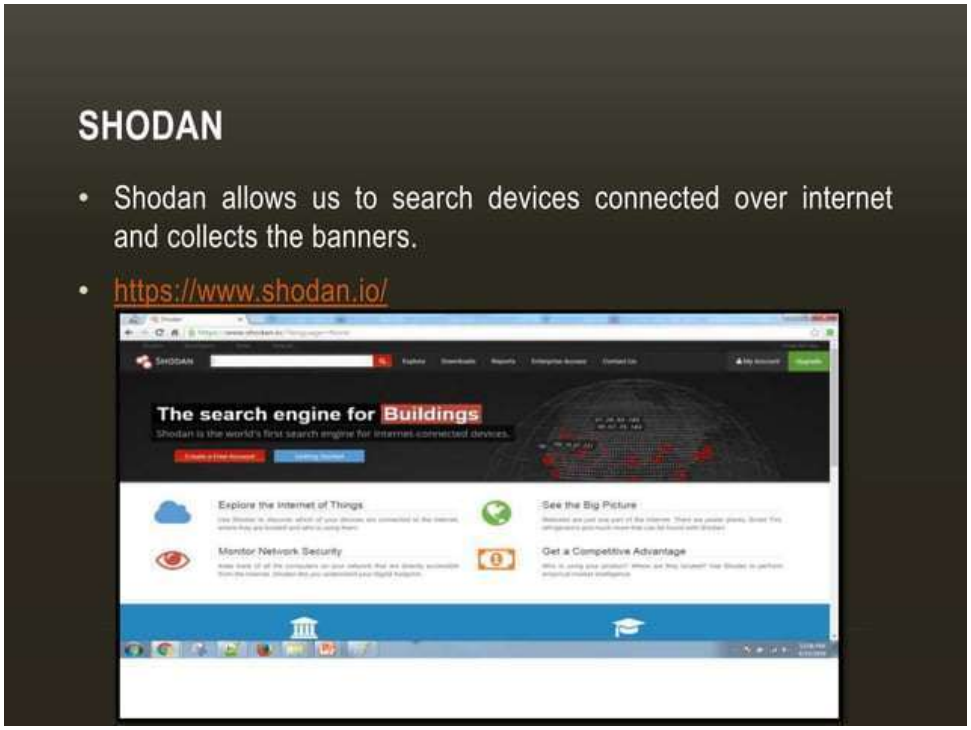
Shodan: internet-connected device intelligence

Notes under the subheading

- Shodan indexes information about devices exposed to the internet.
- It may show open ports, banners, service names and known vulnerabilities.
- Use it to understand exposure; do not interact with systems without permission.
- Filter results only for approved lab assets, owned systems or classroom-safe examples.
- Defensive value: find accidental exposure before attackers abuse it.

Shodan is a visibility tool; authorization still controls what you may test.

Shodan example visual



• Teaching prompt: what defensive questions should a security team ask after seeing exposed services?

Recon-ng: modular reconnaissance framework

Notes under the subheading

- Recon-ng is a command-line, modular web reconnaissance framework.
- It automates information-gathering tasks such as DNS enumeration and contact discovery.
- It can integrate with APIs such as search engines or Shodan.
- It should be used only in lab or approved engagements.
- The professional skill is documenting method, source and defensive meaning.

Automation saves time, but it does not replace judgement.

Recon-ng visual from attached notes



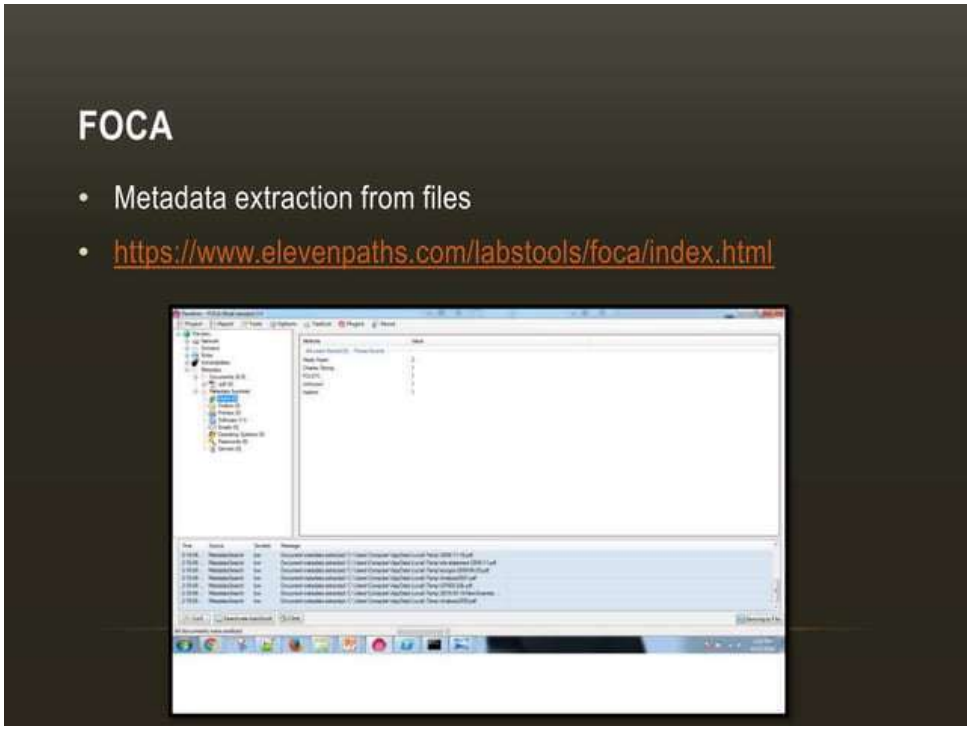
FOCA and metadata extraction

Notes under the subheading

- FOCA focuses on metadata hidden in public documents.
- Metadata may reveal usernames, software versions, author names or network paths.
- Defenders should remove unnecessary metadata before publishing documents.
- Students should practise only on sample files provided for class.
- The ethical goal is to reduce accidental information leakage.

Metadata is “data about data” — and it can expose sensitive clues.

FOCA visual from attached notes



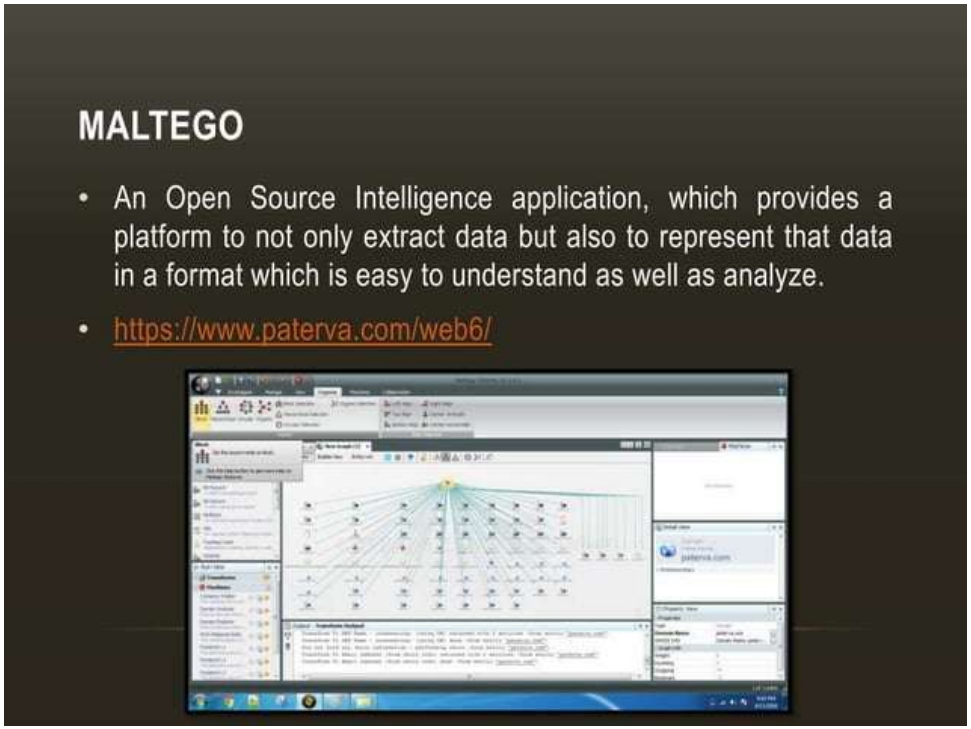
Maltego: link analysis and investigation

Notes under the subheading

- Maltego maps relationships between people, domains, organisations and online identifiers.
- It presents information as a graph for easier investigation and analysis.
- It is useful for threat intelligence, fraud investigation and public-footprint review.
- Students should avoid collecting unnecessary personal information.
- Document sources and explain why each relationship matters.

Good analysts turn scattered clues into a clear map.

Maltego visual from attached notes



Other useful OSINT tools

Have I Been Pwned

- Checks whether an email or domain appears in known breaches.
- Useful for credential-exposure monitoring.
- Supports awareness and password-reset campaigns.
- Do not expose or shame affected users.

WHOIS lookup

- Retrieves public domain registration information.
- Shows registrar, dates and name-server details.
- Helps map domain ownership and infrastructure history.
- Some details may be privacy-protected or outdated.

Technology and reputation tools

BuiltWith

- Detects website technology stacks such as CMS, frameworks and analytics tools.
- Helps identify outdated or risky public technologies.
- Useful for inventory and competitor awareness.
- Validate findings before reporting them.

VirusTotal

- Checks file hashes, URLs and indicators against multiple engines.
- Useful for reputation and initial triage.
- Avoid uploading sensitive internal files without approval.
- Use hashes when possible to protect confidentiality.

Additional OSINT resources



DNS and WHOIS interrogation

- DNS records can reveal domains, subdomains, mail services and name servers.
- WHOIS may reveal domain registration and administrative information.
- Certificate records may reveal forgotten hostnames or test systems.
- Compare multiple sources before drawing conclusions.
- Report only what is relevant to the authorised security objective.

DNS often reveals how an organisation is structured online.

Metadata and privacy concerns

- Metadata may include author names, edit history, software versions and timestamps.
- Published documents can unintentionally reveal internal systems or naming conventions.
- Images may contain location or device details when not cleaned properly.
- Security teams should use metadata review before publication.
- Students must practise data minimisation and avoid unnecessary personal data collection.

Do not collect more than you need to prove the risk.

Building an attack-surface map

Assets

- Domains and subdomains.
- Web apps and APIs.
- Cloud services and storage.
- User endpoints and exposed portals.

Entry points

- Login and password reset pages.
- File uploads and admin panels.
- Open services and public repositories.
- Third-party integrations.

Evidence

- Source URL or screenshot.
- Date and time collected.
- Why it matters for risk.
- Recommended defensive action.

Risk signals found during reconnaissance

- Exposed administration panels or login portals.
- Outdated technologies shown by banners or public pages.
- Public repositories containing secrets or configuration files.
- Leaked credentials or email patterns found in breach datasets.
- Documents containing metadata that reveals internal usernames or systems.

A recon finding becomes useful when it is linked to risk.

How defenders reduce reconnaissance value

Reduce exposure

- Remove unnecessary public services.
- Clean metadata before publishing.
- Disable directory listing and verbose banners.
- Review public repositories.

Strengthen identity

- Enable MFA on exposed portals.
- Use least privilege and strong password policy.
- Monitor failed logins and unusual activity.
- Rotate exposed credentials immediately.

Monitor and respond

- Watch DNS, certificate and brand impersonation changes.
- Alert on scanning patterns.
- Maintain asset inventory.
- Track actions in the risk register.

Knowledge check

Answer these questions in class

- What is the difference between reconnaissance and OSINT?
- Why is passive reconnaissance usually lower risk than active reconnaissance?
- Name three OSINT sources and explain what each can reveal.
- Why can metadata become a security or privacy concern?
- How can reconnaissance findings improve defensive security?

Use examples, not memorised definitions.

Unit 3 summary

Key takeaways

- Reconnaissance is the first information-gathering stage of ethical hacking.
- OSINT uses publicly available information to understand the target footprint.
- Passive recon avoids direct target interaction; active recon requires stronger authorization.
- Tools such as Shodan, Recon-ng, FOCA and Maltego help organise public intelligence.
- The professional outcome is better defence: reduced exposure, stronger monitoring and clear reporting.

Find. Understand. Protect.